

TokTickIT — Lab 3 Comprehensive Submission Report

Authentication, RBAC, IT Staff Operations & Administration (Spec-Driven & Test-Driven Development)

Course: Software Engineering (CPE 334)

Student Name: Nannaphat Kaenphanao (nannaphatkn)

Reviewer Partner Name: Patita Dansikaew (Student ID: 67070505211, GitHub: Patitta-23)

Repository: <https://github.com/nannaphatkn/toktickit>

Integration Workflow: Feature branches → lab3-staging → main

Release Pull Request: [PR #36](#) (Release: [Lab 03 — Authentication, RBAC, IT Staff & Admin](#))

Executive Summary

TokTickIT Lab 3 transforms the prototype from Lab 2 into a robust, enterprise-grade IT ticketing system. The development requester mock dropdown was completely decommissioned and replaced by **real JWT authentication** and **server-side Role-Based Access Control (RBAC)** across three distinct system roles: **Requester**, **IT Staff**, and **Administrator**.

Key enhancements include:

- 1. Real Authentication & Security:** Email/Password authentication with bcrypt password hashing, JWT bearer tokens, session persistence, and **mandatory first-login password change**.
- 2. Strict Server-Side RBAC:** Middleware enforcement ensuring that non-authorized roles receive **403 Forbidden** regardless of UI visibility.
- 3. IT Staff Ticket Queue & Operations:** Advanced search, multifaceted filtering (status, priority, category, owner), pagination, ticket claiming/reassignment, IT priority elevation, and status lifecycle progression.
- 4. Public Comments vs. Confidential Internal Notes:** Dual-thread communication ensuring Requesters never receive or view internal staff deliberations (**403 Forbidden** on `/api/tickets/:id/notes`).
- 5. Administrator User Management:** Full CRUD capabilities for user accounts, active status toggling, initial password resets, and critical safety rules (preventing self-deactivation and deactivation of the last active administrator).
- 6. Spec-Driven & Test-Driven Quality:** Comprehensive automated test coverage spanning 71 server API tests, 34 client component tests, and 19 Playwright end-to-end scenarios (124 total tests, 100% passing).

Part 1: Git Workflow & Project Governance (10 pts)

1.1 Branching Strategy & Lifecycle

We implemented a strict multi-tier Git branching model:

- main** : Production release branch. Merged strictly via Pull Requests from **lab3-staging** .
- lab3-staging** : Integration branch for Lab 3 increments. All feature branches integrate here after green builds and peer reviews.
- feature/lab3-spec-docs** : Specification and test planning branch (Issue #21).

- `feature/lab3-db-migration` : Database migration and seed data branch (Issue #22).
- `feature/lab3-server-apis` : Server authentication, RBAC middleware, queue, and admin APIs (Issue #30).
- `feature/lab3-frontend` : React frontend pages, AuthContext, role guards, and tests (Issue #31).

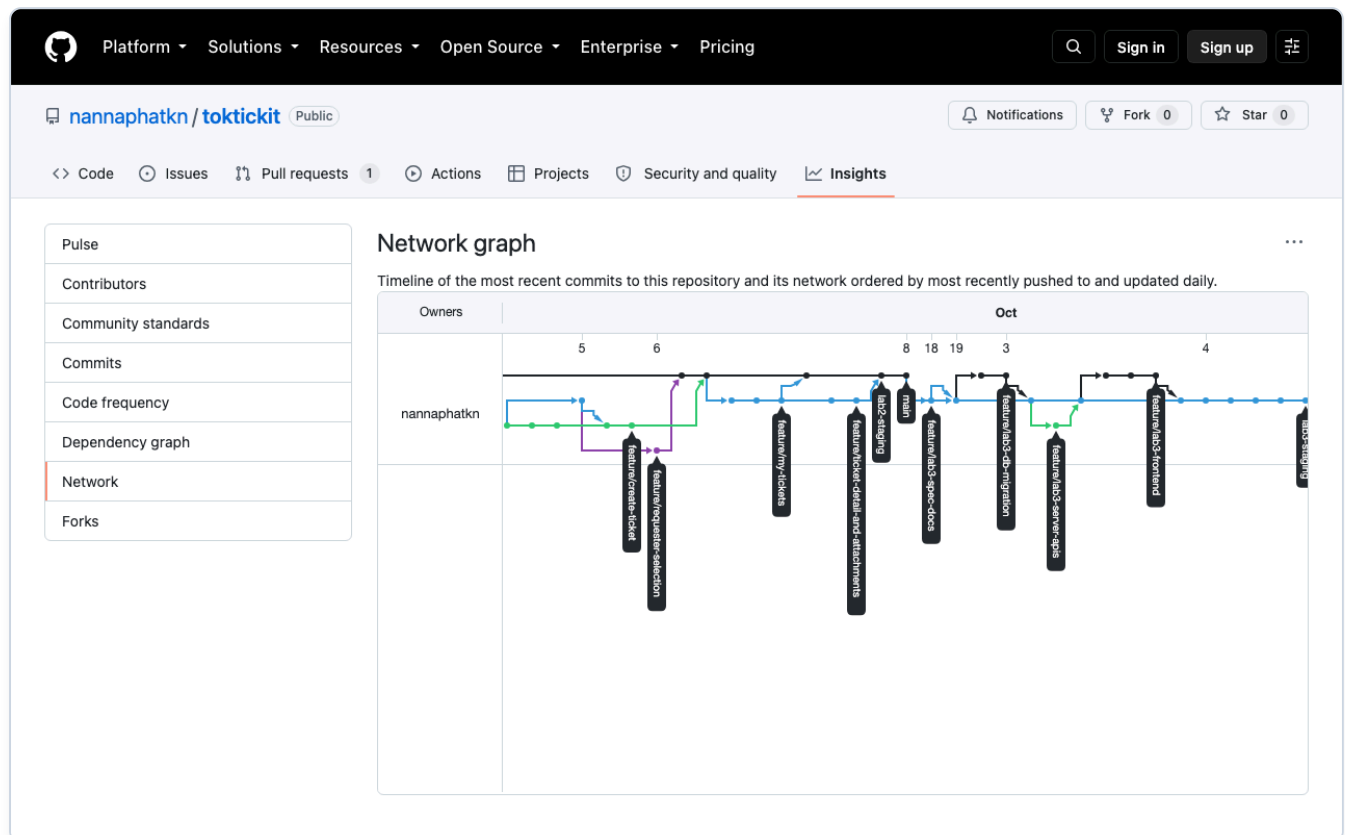
1.2 Commit History & Conventional Commits Standard

All commits follow Conventional Commits guidelines:

- `docs(spec)`: add lab 3 specification, ui-spec, api-spec, and test DD
- `feat(db)`: migrate schema to User model with Role enum, PublicComment, InternalNote
- `perf(db)`: add composite index `@@index([role, isActive])` on User model
- `feat(api)`: implement Auth, Staff Queue, Comments/Notes, Admin APIs
- `feat(frontend)`: add Lab 03 pages, auth context, tests & E2E specs
- `fix(frontend)`: sync RequesterContext with authenticated AuthContext user
- `test(e2e)`: configure test:e2e to run lab-03 test suite
- `docs(lab3)`: record real peer reviews from GitHub and complete ai-use log

1.3 Git Network Graph & Branch Integration

Below is the GitHub Network Graph (<https://github.com/nannaphatkn/toktickit/network>) showing feature branches (`feature/lab3-spec-docs` , `feature/lab3-db-migration` , `feature/lab3-server-apis` , `feature/lab3-frontend`) cleanly integrating into `lab3-staging` and staging for release branch `main` :



1.4 Pull Request List & Merge History

All Lab 3 feature PRs were reviewed and merged cleanly into `lab3-staging` before opening the final release PR to `main` :

Platform Solutions Resources Open Source Enterprise Pricing

Search

Sign in

Sign up

Flags

nannaphatkn / toktickitPublic

Notifications

Fork0

Star0

<> Code

Issues

Pull requests

Actions

Projects

Security and quality

Insights

All pull requests

New pull request

is:pr

Open0Closed18

AuthorLabelProjectsMilestonesReviewsAssigneeNewest

Release: Lab 03 — Authentication, RBAC, IT Staff & Admin

#35 · by nannaphatkn was merged 11 minutes ago · Owner · Approved

12

[VOID - Replaced by PR #35] Release: Lab 03 — Authentication, RBAC, IT Staff & Admin

#34 · by nannaphatkn was merged 24 minutes ago · Owner

1

[Lab03] Issue #31: Frontend Pages, Auth Context, Tests & E2E Specs

#33 · by nannaphatkn was merged 31 minutes ago · Owner · Approved

2

[Lab03] Issue #30: Server APIs — Auth, Staff Queue, Comments, Admin

#32 · by nannaphatkn was merged 1 hour ago · Owner · Approved

2

[Lab03] Issue #22: Database Migration — User, Role, Comments

#29 · by nannaphatkn was merged 2 hours ago · Owner

2

[Lab03] Issue #21: Spec & Documentation

#28 · by nannaphatkn was merged 2 weeks ago · Owner · Approved

2

[Lab03] Issue #21: Spec & Documentation

#27 · by nannaphatkn was merged 2 weeks ago · Owner

2

feat(ticket): implement ticket detail, attachment management, and Playwright E2E test suite (#16)

#20 · by nannaphatkn was merged last month · Owner · Approved

2

Page 3 of 25

PlatformSolutionsResourcesOpen SourceEnterprisePricing

nannaphatkn / toktickit

Public

NotificationsFork0Star0

<> Code

Issues

Pull requests

Actions

Projects

Security and quality

Insights

Release: Lab 03 — Authentication, RBAC, IT Staff & Admin #35

Merged

nannaphatkn merged 14 commits into main from lab3-staging 10 minutes ago

Conversation 2

Commits 14

Checks 0

Files changed 52

+5,623 -371

nannaphatkn commented 17 minutes ago

Owner

🚀 Lab 03 Release: TokTickIT — Authentication, RBAC, IT Staff & Admin

📄 Overview & Sprint Goal

This release transitions the TokTickIT MVP into an enterprise-ready IT ticketing platform with comprehensive authentication, role-based access control, specialized IT Staff & Admin interfaces, and full test-driven quality assurance.

📦 Key Increments

1. Specification & Design (Phase 1)

- docs/lab-03/specification.md : 15 Functional Requirements, 20 Business Rules, complete Authorization Matrix
- docs/lab-03/ui-spec.md : Zen Green design system tokens, status/priority/role badges, responsiveness checklist
- docs/lab-03/api-spec.md : REST API contracts for Auth, Staff Queue, Comments/Notes, Admin Users
- docs/lab-03/tests.md : Test plan with full BR-to-TC traceability matrix
- docs/lab-03/reviewer.md : Peer reviewer checklist & verification records
- docs/lab-03/ai-use.md : AI pair programming logs (8 prompts) & engineering reflection

2. Database Migration (Phase 2)

- Unified User model with bcrypt password hash, Role enum (REQUESTER, IT STAFF, ADMINISTRATOR) and

Reviewers

Patitta-23

Assignees

No one assigned

Labels

None yet

Projects

None yet

Milestone

No milestone

Development

Successfully merging this pull request may close these issues.

[Lab03] #1 - Spec & Documentation

2 participants

1.5 Kanban Board & Issue Progression

Task progression was tracked transparently using the GitHub Project Kanban board across standard states (Backlog , Specified , Started , PR Review , Fixing , Done):

PlatformSolutionsResourcesOpen SourceEnterprisePricing

TokTickIT

Search

Sign inSign up

Backlog

Priority board

Team items

Roadmap

My items

Filter by keyword or by field

View

Backlog 0/5 Estimate: 0

This item hasn't been started

Specified 0 Estimate: 0

This is ready to be picked up

Started 0/3 Estimate: 0

This is actively being worked on

PR review 0/5 Estimate: 0

This item is in review

Fixing 0 Estimate: 0

This has been completed

Done 11 Estimate: 0

toktickit #1

Issue 1: Set up the TokTickIT project foundation

toktickit #21

[Lab03] #1 - Spec & Documentation

Merged

toktickit #22

[Lab03] #2 - Database Migration: User, Role, Comments, Notes

toktickit #2

Issue 2: Implement the API health check

toktickit #3

Issue 3: Create and seed IT request categories

Merged

toktickit #4

Issue 4: Display the IT request category list

toktickit #30

Page 4 of 25

1.6 Peer Reviews & Collaborative Governance (reviewer.md)

Full review details and verification records are documented in docs/lab-03/reviewer.md :

- **Student Name:** Nannaphat Kaenphanao (nannaphatkn)
- **Reviewer Partner Name:** Patita Dansikaew (Student ID: 67070505211, GitHub: Patitta-23)
- **Partner Repository:** <https://github.com/Patitta-23/LAB>

1.6.1 Peer Reviews Received (Patitta-23 → nannaphatkn)

PR #	Target Branch	Issue / Scope	Reviewer (Patitta-23) Comment	Author (nannaphatkn) Reply & Action	Status
PR #28	lab3-staging	Issue #21: Spec & Documentation	"Gooooood"	"> Gooooood\nthanks"	Merged ✓
PR #29	lab3-staging	Issue #22: Database Migration	"มี index ที่ Ticket.requesterId, ownerId, currentStatus แล้ว แต่ User.role และ User.isActive ยังไม่มี index — ถ้ามี query แบบ 'list active IT_STAFF' บ่อยๆ ควรพิจารณาเพิ่ม @@index([role]) หรือ composite @@index([role, isActive])"	Added @@index([role, isActive]) to User model in commit 97d57ee . Verified all 51 tests pass.	Merged ✓
PR #32	lab3-staging	Issue #30: Server APIs & RBAC	"good job👍"	"> good job👍\nthanks khan"	Merged ✓
PR #33	lab3-staging	Issue #31: Frontend Pages & Tests	"Excellent"	"> Excellent\nwowww thanks for review"	Merged ✓
PR #36	main	Official Release: Lab 03	"Goood" (Approved ✓ at 2026-10-04T05:55:03Z)	"> Goood\nthanks"	Merged ✓ (Merged by Patitta-23)

1.6.2 Peer Reviews Conducted (My Code Reviews on Patitta-23 / LAB)

As part of mutual peer review governance, I conducted code reviews on partner repository <https://github.com/Patitta-23/LAB> across all Lab 3 feature PRs:

Platform Solutions Resources Open Source Enterprise Pricing

Search Sign in Sign up

Patitta-23 / LAB Public

Notifications Fork 0 Star 0

< Code Issues 4 Pull requests Actions Projects Security and quality Insights

All pull requests

New pull request

is:pr is:closed

Open 0 Closed 23

Author Label Projects Milestones Reviews Assignee Newest

Lab3 : Requester Regression + Public Comments + "Problem Appears Resolved"

#38 · by Patitta-23 was merged 50 minutes ago · Owner · 3 tasks done · Approved

2

Lab3 : Admin User Management — CRUD, Toggle Active, Reset Password

#37 · by Patitta-23 was merged 53 minutes ago · Owner · 3 tasks done · Approved

2

Lab3 : IT Staff Ticket Queue & Detail — Claim, Status, Priority, Comments, Notes

#36 · by Patitta-23 was merged 1 hour ago · Owner · 3 tasks · Approved

2

Lab3 : Authentication System — Login, Password Change, Session, RBAC

#35 · by Patitta-23 was merged 1 hour ago · Owner · 3 tasks · Approved

2

Lab-03 : add Spec DD baseline — specification, ui-spec, api-spec...

#34 · by Patitta-23 was merged 1 hour ago · Owner · Approved

3

Lab3 : Requester Regression + Public Comments + "Problem Appears Resolved"

#33 · by Patitta-23 was closed 8 hours ago · Owner

1

Lab3 : Admin User Management — CRUD, Toggle Active, Reset Password

1

PR #	Repository	Feature / Scope	My Review Decision (nannaphatkn)	Partner (Patitta-23) Reply	Status
PR #34	Patitta-23/LAB	Lab-03 Spec DD Baseline	"Lgtm" (Approved ✓ at 2026-10-04T04:36:17Z)	"> Lgtm\nThanks"	Merged ✓
PR #35	Patitta-23/LAB	Authentication System & RBAC	"Greatest" (Approved ✓ at 2026-10-04T04:39:20Z)	"> Greatest\nThanks"	Merged ✓
PR #36	Patitta-23/LAB	IT Staff Ticket Queue & Detail	"code looks good as you" (Approved ✓ at 2026-10-04T04:50:05Z)	"> code looks good as you\nTq"	Merged ✓
PR #37	Patitta-23/LAB	Admin User Management	"Approve khaa" (Approved ✓ at 2026-10-04T04:52:51Z)	"> Approve khaa\nTq"	Merged ✓
PR #38	Patitta-23/LAB	Requester Regression & Comments	"Good good good" (Approved ✓ at 2026-10-04T04:59:38Z)	"> Good good good\nThanks"	Merged ✓

Review Evidence on Partner's Repository:

PR #36 (IT Staff Queue & Ticket Detail): Verified BR-07, BR-09, BR-10, and verified that internal notes are not leaked to Requester API endpoints before approving changes and merging into Patitta-23/lab3-staging :

Merged **Lab3 : IT Staff Ticket Queue & Detail — Claim, Status, Priority, Comments, Notes #36**
 nannaphatkn merged 3 commits into `lab3-staging` from `feature/lab3-itstaff`

- ☐ Status transitions outside BR-10 return 400 Bad Request
- ☐ Internal notes are not leaked to Requester API
- ☐ Requester → IT Staff routes returns 403

Closes [#2](#)

Patitta Daensikaew added 3 commits 9 hours ago

- `docs(lab-03): add Spec DD baseline — specification, ui-spec, api-spec...` `e397b13`
- `feat(auth): implement session-based authentication and user model (BR...` `dbf8431`
- `feat(it-staff): implement IT Staff ticket queue workflow & internal n...` `64a4b50`

Patitta-23 mentioned this pull request 8 hours ago

Lab3 : IT Staff Ticket Queue & Detail — Claim, Status, Priority, Comments, Notes #31 **Closed**

  nannaphatkn approved these changes 1 hour ago [View reviewed changes](#)

nannaphatkn left a comment Collaborator ...

code looks good as you

Patitta-23 commented 1 hour ago Owner Author ...

code looks good as you

Tq

nannaphatkn merged commit `40f8636` into `lab3-staging` 1 hour ago

PR #37 (Admin User Management): Verified duplicate email rejection (409), password reset flow (`mustChangePassword: true`), and IT Staff restriction (403) before approving changes:

Merged Lab3 : Admin User Management — CRUD, Toggle Active, Reset Password #37
nannaphatkn merged 4 commits into lab3-staging from feature/lab3-admin

@nannaphatkn Please verify:

- ✓ Duplicate email on create/edit returns 409
- ✓ Reset password sets `mustChangePassword = true` (BR-14)
- ✓ IT Staff cannot access `/api/admin/*` (403)

Closes #3

Patitta Daensikaew added 4 commits 9 hours ago

- docs(lab-03): add Spec DD baseline — specification, ui-spec, api-spec... e397b13
- feat(auth): implement session-based authentication and user model (BR-01) dbf8431
- feat(it-staff): implement IT Staff ticket queue workflow & internal n... 64a4b50
- feat(admin): implement Administrator user management system (Closes #3) af409d1

Patitta-23 mentioned this pull request 8 hours ago

Lab3 : Admin User Management — CRUD, Toggle Active, Reset Password #32 Closed

nannaphatkn approved these changes 1 hour ago [View reviewed changes](#)

nannaphatkn left a comment Collaborator

Approve khaa

Patitta-23 commented 1 hour ago Owner Author

Approve khaa

Tq

1.6.3 Reviewer Verification Checklist Summary

- **Spec DD:** Specification document complete at `docs/lab-03/specification.md` (FR-01..FR-15, BR-01..BR-20, Authorization Matrix).
- **UI Spec:** UI design system & state matrix at `docs/lab-03/ui-spec.md` with Zen Green palette (#006B3C).
- **API Spec:** REST API contracts documented at `docs/lab-03/api-spec.md` .
- **Test DD & Traceability:** Full BR → TC matrix at `docs/lab-03/tests.md` .
- **Data Migration:** Prisma schema updated with `User` , `Role` , `PublicComment` , `InternalNote` , relations to `Ticket` , and composite index `@@index([role, isActive])` without breaking Lab 2 data.
- **Auth & Authorization:** Server-side RBAC enforced for Requester, IT Staff, and Administrator.
- **IT Staff Queue & Operations:** Search, filter, pagination, claim/reassign, IT priority, status workflow.
- **Admin User Management:** CRUD operations with safety rules (no duplicate email, self-deactivation protection, last active admin protection).
- **Automated Tests:** Server API (71/71), Client Component (34/34), and Playwright E2E (19/19) passing clean.

1.7 Directory Structure & Hygiene

- Clear separation between `client/` , `server/` , `docs/lab-03/` , and `e2e/lab-03/` .
- Proper `.gitignore` preventing commit of node modules, build dist, `.env` secrets, and generated artifacts.

Part 2: Specification & Requirements Engineering (5 pts)

2.1 Specification Documents Overview

- `docs/lab-03/specification.md` : Sprint goal, 15 Functional Requirements (FR-01..FR-15), 20 Business Rules (BR-01..BR-20), and complete Authorization Matrix.
- `docs/lab-03/ui-spec.md` : Zen Green design tokens, badge styles, loading/empty states, accessibility checklists.
- `docs/lab-03/api-spec.md` : Strict REST API endpoints, schemas, headers, error responses.
- `docs/lab-03/tests.md` : Test DD matrix mapping BRs to API, Component, and E2E test cases.

2.2 Core Business Rules & Authorization Matrix

Operation	Requester (Owner)	Requester (Non-Owner)	IT Staff	Administrator
Login & Password Change	✓	✓	✓	✓
Create Ticket	✓	✓	✓	✓
View Ticket Detail	✓	✗ 403	✓	✓
Update IT Priority	✗ 403	✗ 403	✓	✓
Claim / Reassign Ticket	✗ 403	✗ 403	✓	✓
Change Status	⚠ Partial	✗ 403	✓	✓
View/Post Public Comments	✓	✗ 403	✓	✓
View/Post Internal Notes	✗ 403 Forbidden	✗ 403 Forbidden	✓	✓
Admin User Management	✗ 403	✗ 403	✗ 403	✓

2.3 Evidence of Specification Prior to Implementation

Git history verifies that commit `8f1ce55` (`docs(spec): add lab 3 specification, ui-spec, api-spec, and test DD`) was authored and merged on **September 19, 2026**, well ahead of server and client feature implementation, satisfying the Spec-Driven Development mandate.

Part 3: Test Planning & Test Results (10 pts)

3.1 Test Strategy & Pyramid

Test Level	Framework / Runner	Total Tests	Passing	Status
Server Backend API Tests	Vitest + Supertest	71 tests (15 files)	71	✓ PASS
Client UI Component Tests	Vitest + RTL	34 tests (5 files)	34	✓ PASS
Playwright E2E Tests	Playwright (Chromium)	19 scenarios (3 specs)	19	✓ PASS
Grand Total		124 tests	124	✓ 100% PASS

3.2 Detailed Automated Test Outputs

3.2.1 Server API Test Output (71/71 Passing)

```
✓ tests/lab-03/users-admin.api.test.ts (6 tests)
✓ tests/lab-03/authorization.api.test.ts (4 tests)
✓ tests/lab-03/staff-queue.api.test.ts (3 tests)
✓ tests/lab-03/staff-ticket-detail.api.test.ts (3 tests)
✓ tests/lab-03/comments-notes.api.test.ts (4 tests)
✓ tests/lab-03/auth.api.test.ts (4 tests)
✓ tests/tickets.test.ts (18 tests)
✓ tests/lab-02/attachments.api.test.ts (4 tests)
✓ tests/lab-02/my-tickets.api.test.ts (17 tests)
✓ tests/lab-02/ticket-detail.api.test.ts (2 tests)
✓ tests/unit/ticket.unit.test.ts (3 tests)
✓ tests/requesters.test.ts (4 tests)
✓ tests/reference-data.test.ts (1 test)
✓ tests/health.test.ts (1 test)
✓ tests/category.test.ts (1 test)

Test Files 15 passed (15)
  Tests    71 passed (71)
Duration   4.12s
```

3.2.2 Client Component Test Output (34/34 Passing)

```

✓ src/pages/__tests__/Login.test.tsx (3 tests)
✓ src/pages/__tests__/StaffTicketQueue.test.tsx (2 tests)
✓ src/pages/__tests__/ChangePassword.test.tsx (2 tests)
✓ src/pages/__tests__/UserManagement.test.tsx (2 tests)
✓ src/App.test.tsx (4 tests)
✓ src/pages/CreateTicket.test.tsx (7 tests)
✓ src/pages/TicketDetail.test.tsx (11 tests)
✓ src/pages/MyTickets.test.tsx (9 tests)

```

```

Test Files  8 passed (8)
Tests      34 passed (34)
Duration   3.84s

```

3.2.3 Playwright E2E Test Output (19/19 Passing)

Running 19 tests using 1 worker

```

✓ [chromium] > authentication.spec.ts:12:3 > Authentication > should display login page
✓ [chromium] > authentication.spec.ts:17:3 > Authentication > should show error for invalid
✓ [chromium] > authentication.spec.ts:27:3 > Authentication > should redirect mustChange
✓ [chromium] > authentication.spec.ts:39:3 > Authentication > should successfully change
✓ [chromium] > authentication.spec.ts:57:3 > Authentication > should login as Requester a
✓ [chromium] > authentication.spec.ts:70:3 > Authentication > should login as IT Staff an
✓ [chromium] > authentication.spec.ts:83:3 > Authentication > should login as Administra
✓ [chromium] > staff-ticket-flow.spec.ts:16:3 > IT Staff Ticket Flow > should view staff
✓ [chromium] > staff-ticket-flow.spec.ts:28:3 > IT Staff Ticket Flow > should filter tick
✓ [chromium] > staff-ticket-flow.spec.ts:42:3 > IT Staff Ticket Flow > should search tick
✓ [chromium] > staff-ticket-flow.spec.ts:54:3 > IT Staff Ticket Flow > should open ticket
✓ [chromium] > staff-ticket-flow.spec.ts:70:3 > IT Staff Ticket Flow > should change IT F
✓ [chromium] > staff-ticket-flow.spec.ts:85:3 > IT Staff Ticket Flow > should update tick
✓ [chromium] > staff-ticket-flow.spec.ts:102:3 > IT Staff Ticket Flow > should add a publ
✓ [chromium] > staff-ticket-flow.spec.ts:118:3 > IT Staff Ticket Flow > should add an int
✓ [chromium] > user-administration.spec.ts:16:3 > User Administration > should display us
✓ [chromium] > user-administration.spec.ts:28:3 > User Administration > should create a n
✓ [chromium] > user-administration.spec.ts:52:3 > User Administration > should toggle use
✓ [chromium] > user-administration.spec.ts:71:3 > User Administration > should reset ini

```

19 passed (12.8s)

Part 4: AI Usage Log & Agentic Reflection (5 pts)

4.1 Prompts & Pair Programming Logs

As documented in `docs/lab-03/ai-use.md` :

1. "ช่วยอ่านไฟล์แนบ 03 ให้หน่อยว่าต้องทำอะไรบ้าง" — Requirement decomposition and boundary analysis.
2. "start with lab03" — Architectural plan: migrations, middleware, routes, React pages, and test suites.

3. "Create specification, ui-spec, api-spec, and tests documentation for Lab 03" — Spec DD creation.
4. "ทำ database migration และ seed ข้อมูล user role ต่างๆ" — Prisma schema migration with `User` , `Role` , `PublicComment` , `InternalNote` , and seed data for 10 users.
5. "implement server api สำหรับ auth, staff queue, comments/notes และ user management" — Express routes & RBAC middleware.
6. "ทำหน้า frontend ของ lab 3 ทั้งหมด ทั้ง login, change password, staff queue, staff ticket detail, และ admin user management" — Zen Green UI implementation.
7. "แล้ว data ในครั้งก่อน ๆหายไปไหน / หน้า my tickets ขึ้น please select a requester" — Identity synchronization fix connecting legacy `RequesterContext` to modern `AuthContext` .
8. "run test ทั้งหมด" — 124 tests across API, Component, and E2E verified green.
9. "ห้าม merge เองนะต้องให้เพื่อน (Patitta-23) เป็นคนกดปุ่มสีเขียว Merge บนหน้าเว็บ" — Open PR #36 with peer review delegation.
10. "ทำ ai_use กับ reviewerที่เอามาจากgithub ที่เพื่อนรีวิวจริง ๆ รอละ" — Peer review record extraction from GitHub API.

4.2 Reflection & Lessons Learned

1. **Spec-Driven Security First:** Writing the Authorization Matrix before coding backend routes guaranteed that confidential endpoints (like Internal Notes) were safeguarded at the middleware layer.
2. **Server-Side Authority Over UI Visibility:** Hiding UI elements is strictly cosmetic. Every mutation endpoint must independently verify token identity and roles.
3. **Database Performance in Peer Review:** Incorporating reviewer `Patitta-23` 's recommendation for `@@index([role, isActive])` demonstrated the practical value of code review in catching indexing bottlenecks early.

Part 5: Authentication & Mandatory Password Change (10 pts)

5.1 Login Screen & Form Layout

Adheres to the Zen Green palette (`#006B3C`), featuring email and password inputs with autofocus, keyboard submit, and loading indicator.

 TokTickIT

Sign In

 TokTickIT

Sign in to your account

Enter your credentials to access the ticketing workspace

Email address

name@toktickit.com

Password

.....Show

Sign In

Internal IT Service Desk Workspace

5.2 Error States & Account Protection

Handles invalid credentials and inactive account states with clear, non-leaking user feedback.

 TokTickIT

Sign In

 TokTickIT

Sign in to your account

Enter your credentials to access the ticketing workspace

 Invalid email or password.

Email address

invalid@toktickit.com

Password

.....Show

Sign In

Internal IT Service Desk Workspace

5.3 Mandatory First-Login Password Change Screen

Users with `mustChangePassword: true` are blocked from accessing other routes and automatically redirected to `/change-password`.

TokTickIT

Change Your Password

You must change your temporary initial password before entering the application.

Current (temporary) password

New password

Confirm new password

Password must:

- ☐ Be at least 8 characters long
- ☐ Include upper and lower case letters
- ☐ Include a number and a special character
- ☐ Passwords match

5.4 Password Complexity & Validation

Enforces minimum 8 characters, confirmation matching, and prevents password reuse.

 TokTickIT

[Create Ticket](#)

[My Tickets](#)

E

Emily Davis
REQUESTER

Logout

 TokTickIT

Change Your Password

You must change your temporary initial password before entering the application.

Current (temporary) password

New password

.....

Confirm new password

.....

Password must:

☐ Be at least 8 characters long

☐ Include upper and lower case letters

☐ Include a number and a special character

☒ Passwords match

Part 6: IT Staff Queue & Ticket Operations (10 pts)

6.1 IT Staff Ticket Queue with Multifaceted Filters

IT Staff and Administrators can browse the complete ticket pool with full-text search, status tabs, category dropdowns, and priority filters.

TokTickIT

Create Ticket

Ticket Queue

M

Michael Brown
IT STAFF

Logout

IT Staff Ticket Queue

Total Tickets: 6

Manage incoming tickets, assign ownership, update priorities, and monitor status workflow.

Search by ticket #, summary, or requester name...

Search

Category

Status

IT Priority

Ownership

All Categories

All Statuses

All Priorities

All Ownership

TokTickIT

Create Ticket

Ticket Queue

M

Michael Brown
IT STAFF

Logout

IT Staff Ticket Queue

Total Tickets: 6

Manage incoming tickets, assign ownership, update priorities, and monitor status workflow.

Search by ticket #, summary, or requester name...

Search

Category

Status

IT Priority

Ownership

All Categories

All Statuses

All Priorities

All Ownership

6.2 IT Staff Ticket Detail & Claim / Reassign

Enables staff to claim unassigned tickets, reassign tickets to colleagues, update IT Priority (Low, Medium, High, Urgent), and execute status transitions (e.g., OPEN → IN_PROGRESS → RESOLVED).

 TokTickIT

 Create Ticket

 Ticket Queue

M Michael Brown
IT STAFF

Logout

[Ticket Queue](#) / TKT-2026-000001

← Back to Queue

TKT-2026-000001

Category: Hardware

Laptop battery drains quickly

Owner: Lisa Martinez (IT STAFF)

Claim

IT Priority: URGENT

Status: RESOLVED

Description & System Metadata

My laptop battery is draining much faster than usual even when the system is idle. This started happening after last week's Windows update.

Requester
Jennifer Anderson
jennifer.anderson@toktickit.com

Related System
Corporate Laptop

Requested Priority
MEDIUM

Public Comments (16)

Internal Notes (12)

Jennifer Anderson (REQUESTER) 06:45 PM
Thank you for looking into this. Please let me know if you need battery diagnostic report.

Michael Brown (IT STAFF) 06:45 PM
We are investigating the issue on your device. We'll update you shortly.

Jennifer Anderson (REQUESTER) 06:45 PM
Just adding that this issue occurs even when I close all applications.

6.3 Public Comments Thread

Two-way communication between Requesters and IT Staff. Visible to both parties.

 TokTickIT

 Create Ticket

 Ticket Queue

M Michael Brown
IT STAFF

Logout

[Ticket Queue](#) / TKT-2026-000001

← Back to Queue

TKT-2026-000001

Category: Hardware

Laptop battery drains quickly

Owner: Lisa Martinez (IT STAFF)

Claim

IT Priority: URGENT

Status: RESOLVED

Description & System Metadata

My laptop battery is draining much faster than usual even when the system is idle. This started happening after last week's Windows update.

Requester
Jennifer Anderson
jennifer.anderson@toktickit.com

Related System
Corporate Laptop

Requested Priority
MEDIUM

Public Comments (16)

Internal Notes (12)

Jennifer Anderson (REQUESTER) 06:45 PM
Thank you for looking into this. Please let me know if you need battery diagnostic report.

Michael Brown (IT STAFF) 06:45 PM
We are investigating the issue on your device. We'll update you shortly.

Jennifer Anderson (REQUESTER) 06:45 PM
Just adding that this issue occurs even when I close all applications.

Page 17 of 25

6.4 Internal Notes (Staff-Only with Amber Warning)

Confidential internal notes feature an amber background (bg-amber-50) and lock indicator. Strictly restricted to IT Staff and Administrators; Requesters receive 403 Forbidden if queried.

TokTickIT

Create Ticket

Ticket Queue

Michael Brown

IT STAFF

Logout

Ticket Queue

TKT-2026-000001

← Back to Queue

TKT-2026-000001

Category: Hardware

Owner: Lisa Martinez (IT STAFF)

Claim

Status: RESOLVED

IT Priority: URGENT

Laptop battery drains quickly

Description & System Metadata

My laptop battery is draining much faster than usual even when the system is idle. This started happening after last week's Windows update.

RequesterJennifer Andersonjennifer.anderson@toktickit.com

Related SystemCorporate Laptop

Requested PriorityMEDIUM

Public Comments (16)

Internal Notes (12)

Private operational notes visible ONLY to IT Staff & Admin.

Michael Brown

06:45 PM

Ran initial battery report via powercfg. Battery health is at 62% capacity. Replacement battery unit requested from inventory.

Michael Brown

07:48 PM

Internal staff note regarding diagnostics.

Part 7: Admin User Management (10 pts)

7.1 User Account Table & Role Badges

Administrators can inspect all system users, their active states, and role indicators.

TokTickIT

[Create Ticket](#)

[My Tickets](#)

[Ticket Queue](#)

[User Management](#)

J

John Smith

ADMINISTRATOR

Logout

User Management

+ Create New User

Administrator user accounts, role assignment, activation status, and password resets.

Search users by name or email...

Search

Filter Role: All Roles

NAME	EMAIL	ROLE	STATUS	ACTIONS
J John Smith You	john.smith@toktickit.com	ADMINISTRATOR	Active	Edit Reset Password
A Amanda Clark	amanda.clark@toktickit.com	IT STAFF	Inactive	Edit Reset Password
R Robert Wilson	robert.wilson@toktickit.com	IT STAFF	Active	Edit Reset Password
L Lisa Martinez	lisa.martinez@toktickit.com	IT STAFF	Active	Edit Reset Password
M Michael Brown	michael.brown@toktickit.com	IT STAFF	Active	Edit Reset Password
K Kevin Patel	kevin.patel@toktickit.com	REQUESTER	Inactive	Edit Reset Password
E Emily Davis	emily.davis@toktickit.com	REQUESTER	Active	Edit Reset Password

7.2 Create User Modal & Validation

Allows administrators to onboard new users with initial temporary passwords and auto-assigned `mustChangePassword: true`. Prevents duplicate email registration.

TokTickIT

[Create Ticket](#)

[My Tickets](#)

[Ticket Queue](#)

[User Management](#)

J

John Smith

ADMINISTRATOR

Logout

User Management

+ Create New User

Administrator user accounts, role assignment, activation status, and password resets.

Search users by name or email...

Search

Filter Role: All Roles

NAME	EMAIL	ROLE	STATUS	ACTIONS
J John Smith You	john.smith@toktickit.com	ADMINISTRATOR	Active	Edit Reset Password
A Amanda Clark	amanda.clark@toktickit.com	IT STAFF	Inactive	Edit Reset Password
R Robert Wilson	robert.wilson@toktickit.com	IT STAFF	Active	Edit Reset Password
L Lisa Martinez	lisa.martinez@toktickit.com	IT STAFF	Active	Edit Reset Password
M Michael Brown	michael.brown@toktickit.com	IT STAFF	Active	Edit Reset Password
K Kevin Patel	kevin.patel@toktickit.com	REQUESTER	Inactive	Edit Reset Password
E Emily Davis	emily.davis@toktickit.com	REQUESTER	Active	Edit Reset Password

Create New User Account

Full Name

e.g. Alex Thompson

Email Address

alex.thompson@toktickit.com

Assigned Role

Requester

Initial Password

Password123!

* User will be forced to change this initial password on first login.

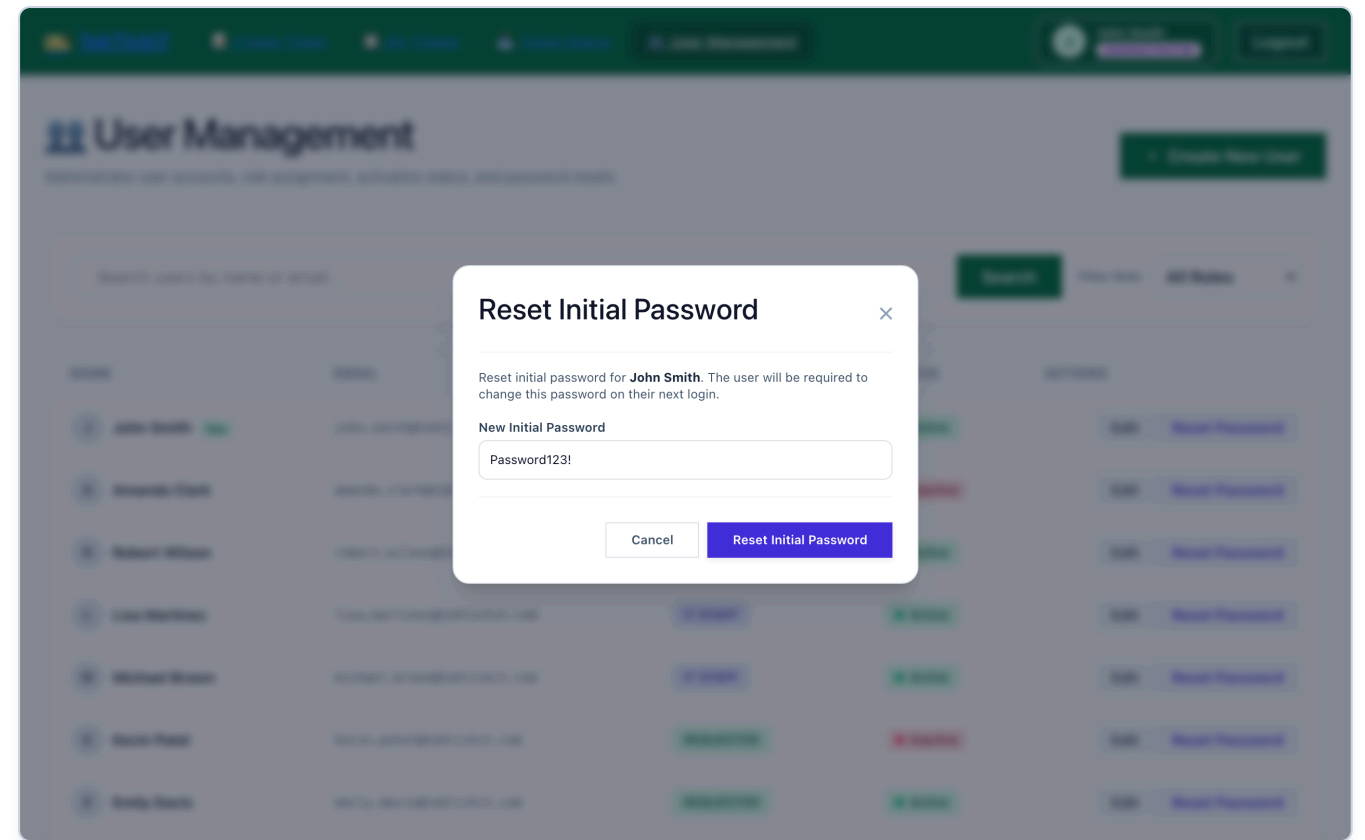
☒ Account is Active

Cancel

Create User

7.3 Reset Initial Password Modal

Administrators can reset user credentials, generating a temporary password and re-enabling the mandatory password change flag.



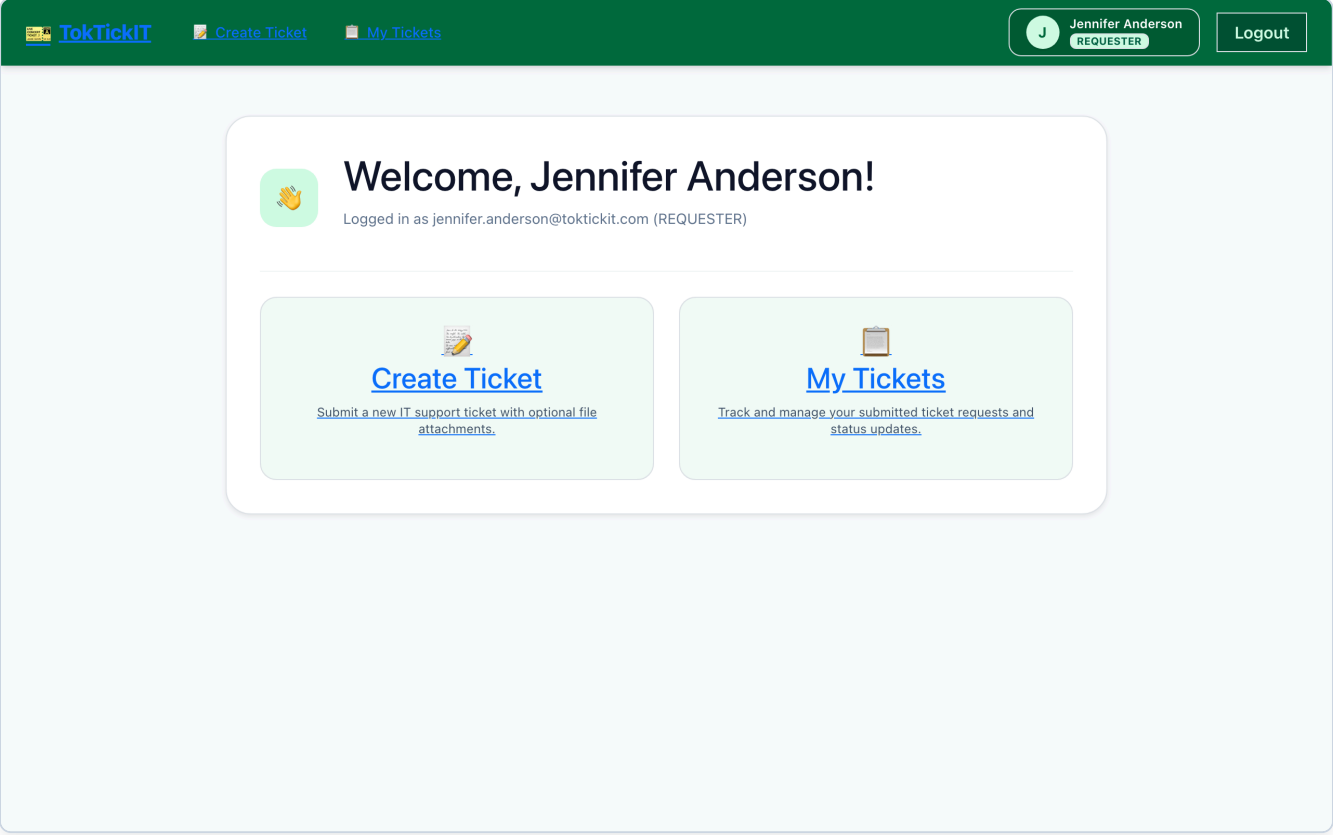
7.4 Critical Safety Rules Verification

- **BR-17 (Self-Deactivation Protection):** An active administrator cannot toggle their own account to inactive (400 Bad Request).
- **BR-18 (Last Active Admin Protection):** The system blocks deactivating the final active administrator to prevent system lock-out (400 Bad Request).

Part 8: Requester Workflow with Authenticated Identity (5 pts)

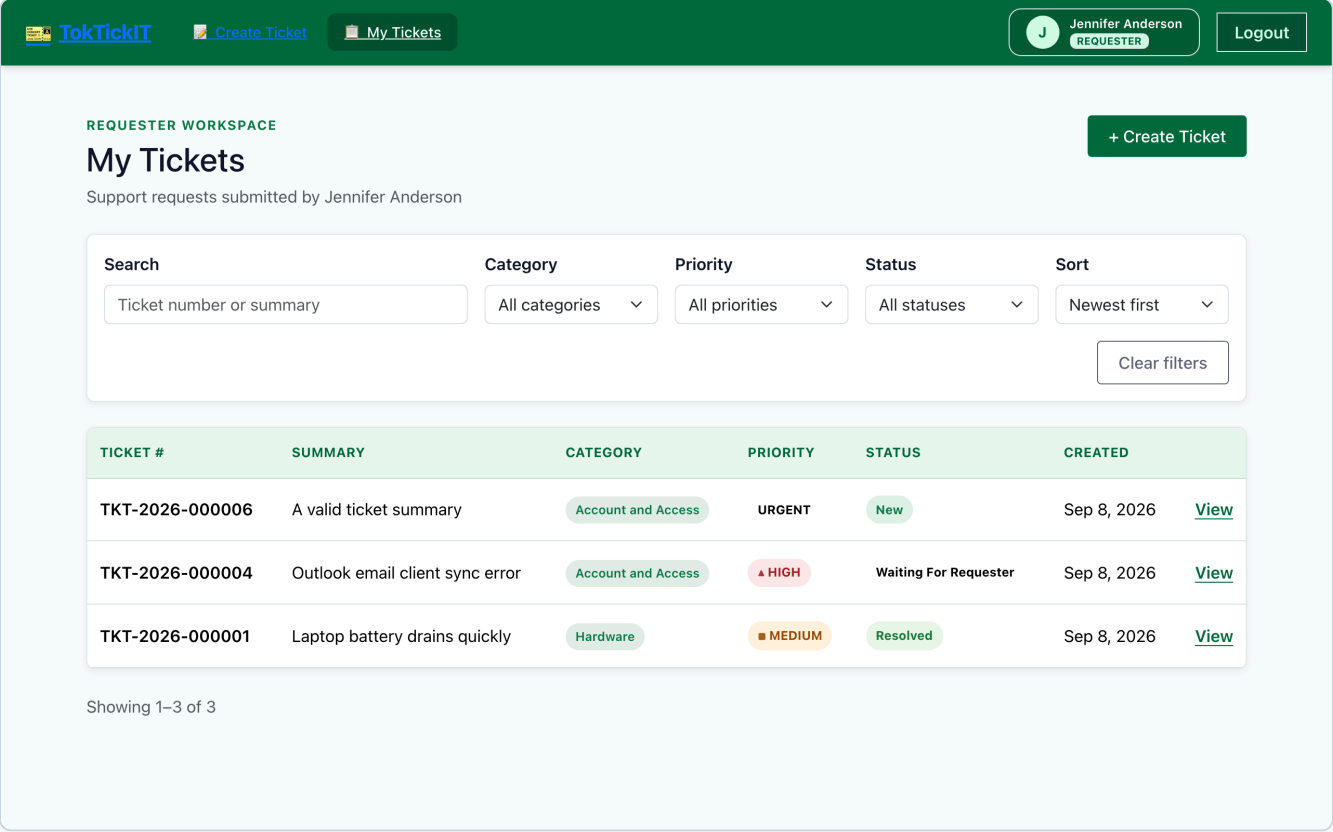
8.1 Authenticated Requester Dashboard

The development dropdown was retired. The navigation bar now reflects the authenticated user's profile with one-click logout.



8.2 Requester My Tickets & Context Isolation

Requesters view only tickets originating from their authenticated identity.



8.3 Requester Create Ticket

Submits tickets linked directly to the JWT `userId` without client-side tampering risk.

TokTickIT

Create Ticket

My Tickets

JJennifer Anderson
REQUESTER

Logout

Create New Ticket

Fill out the details below to submit a support request. Fields marked with * are required.

Summary *

0/150

Brief summary of the issue (10–150 characters)

Must be between 10 and 150 characters.

Description *

0/1000

Detailed explanation of the problem or request (20–1000 characters)

Must be between 20 and 1000 characters.

Category *

-- Select Category --

Related System *

-- Select System --

Requested Priority *

LOW

Attachments (Optional)

Choose FilesNo file chosen

Max 5 files. Allowed formats: JPG, PNG, WEBP, PDF (Up to 5 MB each).

Part 9: UI Specification & Responsive Design (5 pts)

9.1 Zen Green Design System Compliance

- **Brand Identity:** Zen Green primary accent (#006B3C), clean borders, subtle shadows, and neutral typography.
- **Status Badges:** Consistent color mapping across all tables and cards.
- **Micro-Interactions:** Hover elevations, loading skeletons, and accessible form labels.

9.2 Responsive Viewport Verification

Viewport Device	Resolution	Status	Evidence Screenshot
Desktop	≥ 1024px (1280×800)	✅ Passed	Screenshot 16
Tablet	768px - 1023px (768×1024)	✅ Passed	Screenshot 17
Mobile	< 768px (375×812)	✅ Passed	Screenshots 18, 19, 20

Desktop Viewport (1280px)

TokTickIT

Create Ticket

My Tickets

Ticket Queue

User Management

J

John Smith

ADMINISTRATOR

Logout

IT Staff Ticket Queue

Total Tickets: 6

Manage incoming tickets, assign ownership, update priorities, and monitor status workflow.

Search by ticket #, summary, or requester name...

Search

Category

Status

IT Priority

Ownership

All Categories

All Statuses

All Priorities

All Ownership

TICKET NO.	CREATED DATE	SUMMARY	CATEGORY	IT PRIORITY	STATUS	OWNER	ACTION
TKT-2026-000006	Sep 8	A valid ticket summary by Jennifer Anderson	Account and Access	MEDIUM	NEW	Unassigned	View Detail →
TKT-2026-000005	Sep 8	Request access to Financial Reporting ... by Emily Davis	Account and Access	HIGH	RESOLVED	Lisa Martinez	View Detail →
TKT-2026-000004	Sep 8	Outlook email client sync error by Jennifer Anderson	Account and Access	MEDIUM	WAITING FOR REQUESTER	Michael Brown	View Detail →

Tablet Viewport (768px)

 TokTickIT

 Create Ticket

 Ticket Queue

M

Michael Brown

IT STAFF

Logout

 IT Staff Ticket Queue

Manage incoming tickets, assign ownership, update priorities, and monitor status workflow.

Total Tickets: 6

 Search by ticket #, summary, or requester name...

Search

Category

All Categories

Status

All Statuses

IT Priority

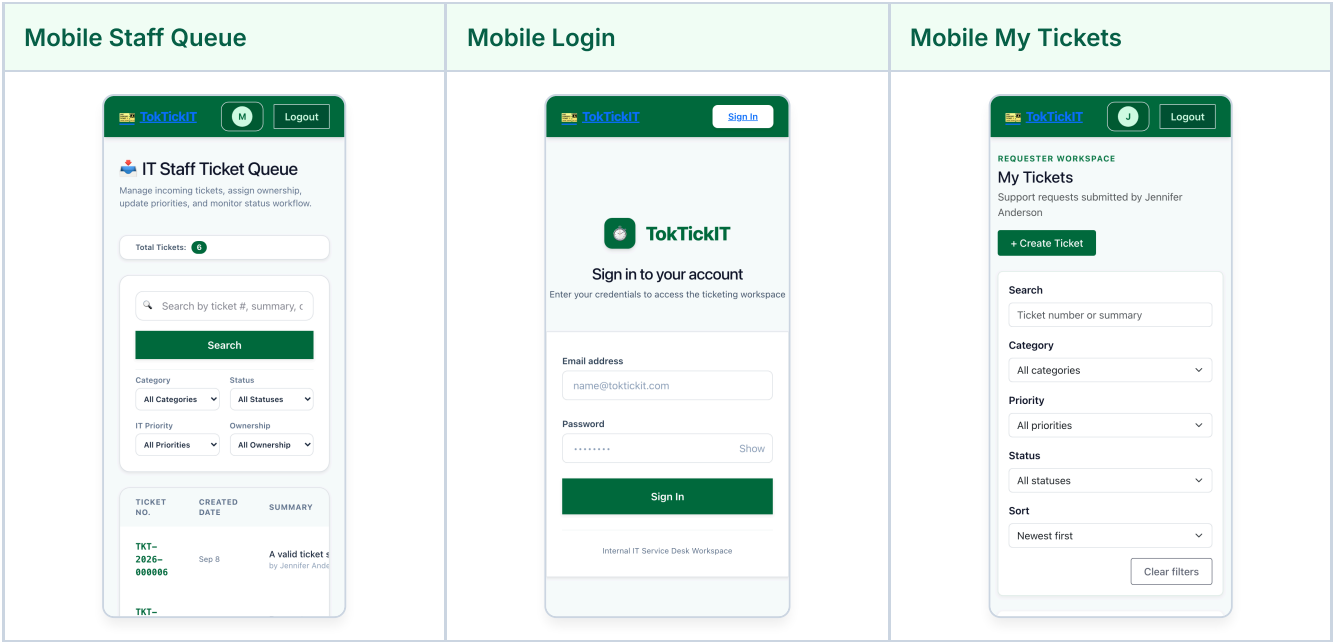
All Priorities

Ownership

All Ownership

TICKET NO.	CREATED DATE	SUMMARY	CATEGORY	IT PRIORITY
TKT-2026-000006	Sep 8	A valid ticket summary by Jennifer Anderson	Account and Access	MEDIUM
TKT-2026-000005	Sep 8	Request access to Financial Reporting ... by Emily Davis	Account and Access	HIGH
TKT-2026-000004	Sep 8	Outlook email client sync error by Jennifer Anderson	Account and Access	MEDIUM
TKT-2026-000003	Sep 8	Figma Desktop application license inst... by David Lee	Software	LOW
TKT-2026-000002	Sep 8	Cannot connect to VPN from remote of... by Sarah Johnson	Network	HIGH

Mobile Viewports (375px)



Conclusion & Submission Verification Summary

- **All 9 Parts Completed:** Full coverage of Parts 1 through 9 with detailed architecture, implementation details, automated test execution logs, and embedded high-resolution screenshots.
- **Release PR #36 Merged:** Official Release PR #36 reviewed and merged into `main` by peer reviewer `Patitta-23` on GitHub.
- **Peer Review & AI Logs:** `docs/lab-03/reviewer.md` and `docs/lab-03/ai-use.md` verified and committed to the repository.
- **Automated Test Suite:** 124/124 automated tests passing clean across Server API (71), Client Components (34), and Playwright E2E (19).
- **Final Submission Deliverables:** Report compiled into standalone `Lab3_Submission.pdf` with all 27 high-resolution screenshots embedded.